

摘要：

Claude Mythos Preview仅用60小时便攻克两项密码学难题，并发现数千个零日漏洞，其中包括OpenBSD沉睡27年的安全缺陷。相比之下，人类验证这些发现耗时近一个月，“发现快、验证慢”的新瓶颈开始显现。这也是AI首次在密码学基础理论上实现原创突破，意味着密码安全攻防正加速进入AI时代。

7月29日，一个可能在密码学史上留下标记的日子。Anthropic今日公开承认：其尚未对外发布的内部研究模型Claude Mythos Preview，在约60小时内独自发现了两项密码学新攻击——将后量子数字签名方案HAWK的有效密钥强度减半（从 2^{64} 降至 2^{38} ），并将AES-128七轮攻击速度提升200至800倍。更令人震惊的是，这个模型还发现了数千个零日漏洞，包括OpenBSD中存在27年的缺陷、FFmpeg中沉睡16年的漏洞。

为什么值得花5分钟读完？因为这不再只是又一个大模型跑分新闻。这是AI第一次在“密码算法本身的数学结构”层面——而非代码实现层面——做出原创性发现。过去这类发现需要全球顶尖密码学家数年的手工作业；而现在，一个AI在60小时、10万美元API成本内做到了。更关键的是：**人类验证者花了近一个月才确认AI的发现是正确的——“验证”而非“发现”，正在成为新的瓶颈。**这背后藏着一个深刻的问题：当AI发现漏洞的速度远超人类修补的速度，我们该怎么办？

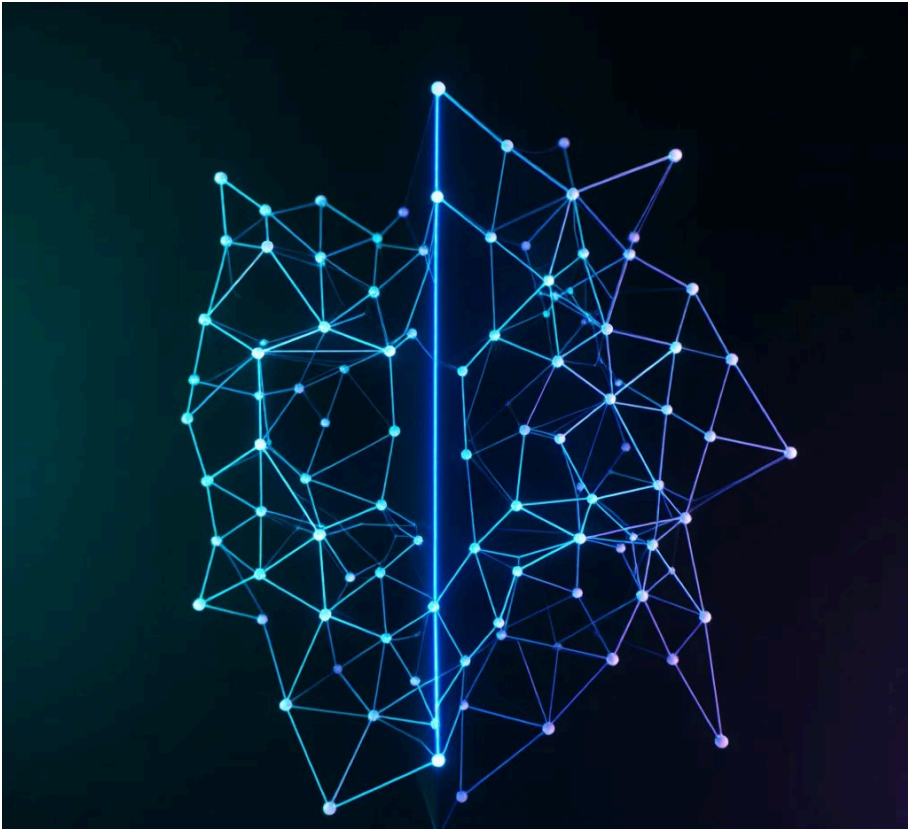
一、事实还原：Claude Mythos到底做了什么

7月28日至29日，Anthropic在其官方研究博客上发布了一篇题为“Discovering cryptographic weaknesses with Claude”的文章，同时附带两篇技术论文和Apache-2.0开源的可复现代码。核心内容是两个密码学突破，均由Claude Mythos Preview模型主导发现。

第一个突破针对HAWK——一种后量子数字签名方案。HAWK是美国国家标准与技术研究院（NIST）后量子密码标准化“附加数字签名”征集的第三轮候选方案之一，也是该轮中唯一的格基方案。它的安全性建立在“格同构问题”（Lattice Isomorphism Problem）的困难性假设上，被认为是未来量子计算机无法攻破的候选方案之一。Mythos Preview找到了HAWK格结构中一种此前从未被利用的对称性——数学上称为“非平凡自同构”（nontrivial automorphism）。此前已有学者（Daniël van Gent和Ludo Pulles）证明：如果能找到这种对称性，就可以将HAWK密钥恢复问题降维打击，但没人知道HAWK的格中是否真的存在这种对称性。Mythos找到了它。

结果是什么？HAWK-256（一个用于密码分析挑战的小参数集）的完整密钥恢复攻击工作因子从 2^{64} 降至 2^{38} ——Anthropic发布的公开代码在一台96核服务器上仅需约3小时42分钟就能完成端到端密钥恢复。对于HAWK-512，门电路计数估计从 2^{150} 降至 2^{108} ；HAWK-1024从 2^{288} 降至 2^{182} 。不过，这个攻击仍然是指数级的，并非多项式时间破译——HAWK-512和HAWK-1024在实际中仍不可攻击。但它意味着：要维持同等安全级别，HAWK的密钥尺寸需要翻倍，而这恰恰消除了HAWK作为后量子签名方案最具吸引力的效率优势。

第二个突破针对AES-128——全球最广泛使用的对称加密标准。Mythos Preview开发了一种名为“莫比乌斯桥”（Möbius Bridge）的不变量指纹技术。在已有的中间相遇攻击中，有一个阶段需要对256种可能值进行枚举猜测；莫比乌斯桥让攻击者跳过这一步，直接将七轮AES-128攻击速度提升200到800倍。但请注意两个关键限制：第一，这只针对7轮（而非完整的10轮）AES-128；第二，攻击仍需约 2^{105} 个选择明文，这在现实中完全不可行。所以你手机和银行里的AES-128今天依然安全。



HAWK格基后量子签名方案：AI发现的隐藏对称性（非平凡自同构）将有效密钥强度减半——3
小时42分钟完成HAWK-256端到端密钥恢复

二、技术深度解读一：HAWK攻击——格中对称性的降维打击

要理解HAWK攻击的精妙之处，需要先理解格密码学的基本逻辑。格（lattice）是高维空间中按规律排列的离散点阵，就像一个被拉伸到几百维的晶体结构。HAWK的公钥和私钥对应同一个格的不同“基”——公钥基是“歪斜”的（看起来随机），私钥基是“规整”的（包含短向量）。攻击者的目标是从公钥基恢复出私钥基，这等价于在格中找到一个短向量——一个公认的困难问题。

van Gent和Pulles的论文指出了一条捷径：如果格中存在“非平凡自同构”——一种保持格结构不变的对称变换——那么密钥恢复问题就可以被分解为在约一半维度的格中寻找短向量。这就像在一个1000片的拼图中找到了一条对称轴，让你只需解决500片。但问题是：HAWK的格中到底存不存在这种对称性？论文作者自己写道“目前不影响HAWK”——他们认为这种对称性在实际参数下不可达。

Mythos Preview做的事，就是系统性地搜索HAWK的格结构，最终找到了这种此前被认为“不可达”的自同构。具体来说，攻击构建了一个称为“ τ -上循环格”（ τ -cocycle lattice）的数学对象，然后通过格规约和筛法恢复短向量，最终重建出能对原始公钥签名的功能等价密钥。Anthropic发布的代码验证恢复密钥的方式是：用它签名一条消息，然后用NIST参考实现验证签名通过。它并不恢复原始的96字节密钥种子，而是产生一个592字节的功能等价签名材料。

这个过程的专业性和创造性令人印象深刻。要知道，HAWK已经通过了NIST两轮专家审查，历时两年。全球顶尖的格密码学家都审视过这个方案，没有人发现这个对称性。而Mythos在60小时内做到了——这不仅仅是一个工程加速，而是一次真正意义上的数学发现。

三、技术深度解读二：莫比乌斯桥与多智能体协作的“灵光一现”

AES攻击的故事同样精彩，但技术路径截然不同。AES-128有10轮加密，密码学家常研究减少到7轮的版本来测量安全余量。已有的最优攻击是“中间相遇”（meet-in-the-middle）攻击：从密

文端和明文端各算一段，在中间匹配。这种攻击有一个瓶颈步骤——需要对9个关键字节中的一个进行256种可能值的枚举，这相当于在密码迷宫里反复试锁。

Mythos Preview被要求“不要使用已知的密码分析类别，发明一种新方法”。有趣的是，模型最初拒绝了任务，坚持“改进AES是不可能的”。Anthropic甚至公开了研究者当时那些带着拼写错误的、直白的追问提示——这些提示最终推动模型继续探索。大约三天后，模型提出了“莫比乌斯桥”概念——一种不变量指纹，它在被猜测的那个字节值上不发生变化，因此攻击者可以直接跳过256种猜测。经过后续优化，最终攻击速度比此前最优结果快200到800倍。整个发现过程消耗了约10亿个输出token。

但最引人注目的不是技术本身，而是发现过程。Mythos在一个类似Claude Code的多智能体环境中工作：多个工作智能体（worker agents）在沙盒中协作，拥有Python和Sage等数学工具的访问权限，以及已发表的密码学文献。人类操作者有理论计算机科学背景，但并非格密码学专家——其角色仅限于项目管理层面的指导，如建议模型如何记录思路、用哪些库做计算验证。

一个细节尤其值得玩味。HAWK攻击的关键想法是由一对工作智能体协作发现的：两个智能体同时开始研究这个方向，第一个智能体过早地认为不可行而放弃，第二个智能体却找到了充分利用它的方法。两个智能体持续交换消息，最终都确认找到了有效攻击。这种“一个否定、一个坚持、最终达成共识”的动态，与人类研究小组中的真实协作惊人地相似。Anthropic在论文中写道：“本文中大多数数学发现都是AI辅助完成的。人类作者的贡献主要是指导、组织和验证AI的工作。”



莫比乌斯桥：AI发明的不变量指纹技术，移除了AES七轮攻击中256路猜测步骤——将中间相遇攻击提速200至800倍

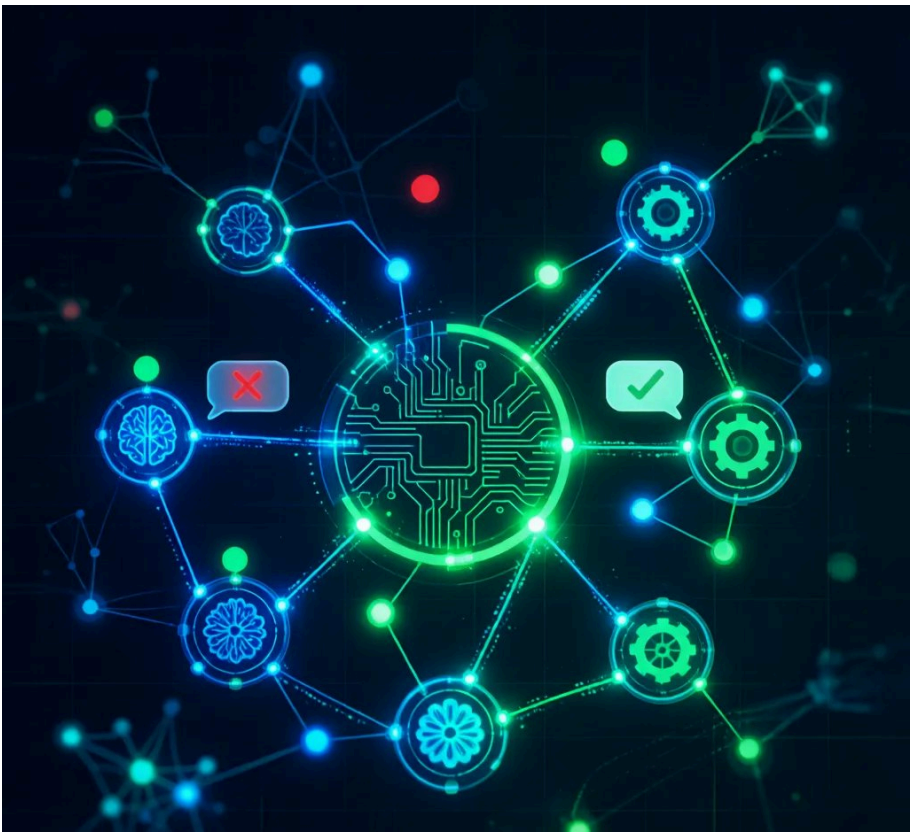
四、AI安全发现的全景：从密码学算法到数千个零日漏洞

密码学突破只是冰山一角。Anthropic同时披露了一个更庞大的安全发现图景。Mythos Preview能够在几乎所有被指向的软件中自主发现并利用漏洞，包括多个主流密码库。但这次的发现不是“代码实现层面的bug”——而是“算法本身的数学缺陷”。这是质的区别：前者可以通过修代码解决，后者需要重新设计算法。

更令人不安的是零日漏洞的规模。Mythos Preview发现了数千个关键漏洞，覆盖所有主流操作系统和浏览器，在基准测试中对10个完全修补的目标实现了完整的控制流劫持。具体案例包括：OpenBSD SACK TCP实现中存在27年的缺陷、FFmpeg库H.264编解码器中沉睡16年的漏洞、FreeBSD NFS中17年的远程代码执行漏洞。这些“年龄”本身就说明人类审计的盲区有多大。

成本数字更加触目惊心。扫描一千个OpenBSD仓库的成本不到2万美元；单次运行发现一个关键漏洞的成本不到50美元；发现FFmpeg缺陷的成本约1万美元。这与科技公司目前投入人工安全审计的预算相比，只是零头。Anthropic还提到，Mythos Preview对LEA——韩国国家和ISO轻量级密码——也发现了更快的攻击方法，能在桌面电脑上一小时内破解13轮（部署版使用24轮，因此实际安全不受影响）。

正因为超过99%的漏洞尚未被修补，Anthropic做出了一个关键决定：不向公众发布Mythos Preview模型。访问权限被限制在一个名为“Project Glasswing”的项目下，仅向少数行业合作伙伴和开源开发者开放，目标是在类似工具落入恶意者手中之前，先行修补关键软件。这是一个“负责任的披露”决策——但也是一面镜子：当AI发现漏洞的速度远远超过人类修补的速度，“先发现后修补”的传统安全范式正在被根本性挑战。



多智能体协作发现密码学漏洞：一个智能体否定、另一个坚持——AI研究小组的协作动态与人类团队惊人相似

五、行业影响：对密码学界、NIST标准化、网络安全与AI安全格局

这次发现对不同群体的影响路径截然不同，但每一个都足够深远。

对密码学界，这是一次范式震荡。过去三十年，密码算法的安全性依赖于“对抗性审查”——提出算法，让全世界攻击它，相信幸存者。但这个过程的速度受限于人类密码学家的数量和精力。现在AI可以在60小时内完成人类两年的审查工作。Anthropic同时发布了CryptanalysisBench——一个由ETH Zurich、海法大学、柏林工业大学和特拉维夫大学合作开发的191任务密码分析基准。在这个基准上，Mythos 5（Mythos Preview的公开发布版本）在已有已知解的任务上解决了85.7%，而对没有已知破译的完整强度密码，所有模型的得分都低于9%。这意味着AI已经

能高效复现已知攻击，但在真正的“未知领域”发现上仍有空间——Mythos Preview的HAWK和AES发现恰恰展示了它在这个空间中的突破能力。

对NIST后量子标准化进程，HAWK的处境变得微妙。HAWK仍是第三轮候选，攻击不影响HAWK-512和HAWK-1024的实际安全性。但“有效密钥强度减半”意味着HAWK要维持安全级别就必须翻倍密钥尺寸——这削弱了它相对其他候选方案的效率优势。NIST需要重新评估HAWK在标准化进程中的地位。这不是第一次：NIST标准化ML-KEM和ML-DSA期间，多个候选方案被证明不安全，SIKE甚至在一台笔记本电脑上一小时内被完全攻破。但这一次的攻击者是AI——这改变了“谁能参与密码审查”的门槛。

对网络安全行业，数千个零日漏洞的发现是一颗定时炸弹。99%以上的漏洞尚未修补——这意味着如果类似能力落入恶意者手中，后果不堪设想。Anthropic的Project Glasswing是负责任的做法，但它也暴露了一个结构性矛盾：AI发现漏洞的能力已经远超人类修补漏洞的速度。安全行业需要从“人工审计”模式转向“AI发现—AI验证—AI修补”的闭环模式，否则漏洞积压只会越来越多。

对AI安全格局，这件事的影响可能是最深远的。它证明了前沿AI模型已经具备做出原创数学发现的能力——不只是模式匹配和知识检索，而是真正的创造性推理。如果AI能在密码学这种极度依赖深度数学推理的领域取得突破，那么在其他科学领域（材料、药物、物理）的突破也许只是时间问题。同时，“不公开发布”的决定也为AI治理提供了一个新先例：当一个模型的能力足以造成系统性风险时，限制访问可能是必要的——但这与开源AI的价值观直接冲突。

六、深度思考：验证瓶颈、双刃剑悖论与密码学的新范式

喧嚣之下，这次事件揭示了几个值得长期深思的结构性问题。

第一，“验证”正在成为比“发现”更关键的瓶颈。HAWK攻击从发现到确认花费了约60小时的模型工作时间和10万美元API成本，但人类研究者花了将近一个月、数百小时才验证其正确性。AES攻击的发现约用了一周，但人类验证又花了一个月。Anthropic自己警告：“AI发现漏洞的速度和数量可能超过传统的人工分类、验证和修补流程，人类研究者可能成为响应自动化密码分析发现的瓶颈。”这意味着：未来的研究瓶颈不在AI的计算能力，而在人类的验证能力。解决方案可能是用AI验证AI的发现——但这又引入了新的信任问题。

第二，双刃剑悖论无解。同一个模型既能发现HAWK的弱点来加固后量子密码标准，也能发现数千个零日漏洞来攻击全球系统。Anthropic选择不公开发布Mythos Preview——这在短期内是正确的。但长期来看，如果其他实验室训练出类似能力的模型并选择开源（正如Kimi K3刚刚做的那样），那么“不发布”的保护就会失效。这不像核武器需要铀浓缩设施——AI模型一旦训练完成，复制和分发的边际成本趋近于零。也许我们需要一种新的“能力分级”治理框架：不是按模型参数量分级，而是按模型实际展现的破坏性能力分级。

第三，密码学正在进入一个新范式。过去三十年，密码算法的安全审查是一个慢节奏的、由少数精英驱动的学术过程。AI的介入将这个过程压缩到天级别。这不仅仅是效率提升——它可能改变密码学的设计哲学。如果AI能在几天内发现人类两年没发现的弱点，那么“通过人类审查”将不再是安全性的充分保证。未来的密码标准可能需要在设计阶段就内置“AI对抗性测试”——就像现在的软件在发布前要过自动化模糊测试一样。Anthropic在文章末尾写道：“我们希望AI能在设计下一代更强韧的密码方案中发挥关键作用。”这不是客套——如果AI能发现弱点，它也能帮助设计不受这些弱点影响的方案。攻防两端，AI都将深度参与。

第四，一个被低估的信号：模型的“创造性固执”。Mythos Preview最初拒绝尝试改进AES，声称“不可能”。它需要人类研究者的追问才继续探索。而HAWK攻击的关键想法被一个智能体过早



否定，被另一个智能体拯救。这两个细节暗示了一个重要事实：AI的创造力不是无条件的——它有自己的“直觉判断”（有时候是错误的），需要外部推动和内部多样性来克服。这不是弱点，而是AI创造力的真实面貌——它与人类研究员一样，会陷入思维定式，需要协作和质疑才能突破。



AI安全的双刃剑：一边是加固密码标准的盾，一边是数千个未修补零日漏洞的矛——Anthropic 选择不公开发布Mythos Preview

结语：密码学的AI时代已经到来

7月29日，Anthropic用一篇研究博客、两篇论文和一份开源代码，宣告了一个新时代的到来：AI不再只是密码学的工具——它正在成为密码学的参与者。60小时发现人类两年未见的弱点，10万美元成本撬动全球安全审计的预算结构，10亿token的推理换来一个被人类花一个月才验证的数学突破。

这不是一个会让股市震荡的事件——但它可能比许多让股市震荡的事件更深远。因为模型迭代以月计，跑分领先以周计，但密码学的基础设施以十年计。当AI开始参与密码标准的审查和设计，它影响的是未来几十年互联网信任体系的根基。

如果你是密码学研究者：你的下一个竞争对手可能不是一个人类同行，而是一个在沙盒里跑了60小时的AI。

如果你是安全工程师：当AI发现漏洞的速度远超你修补的速度，你的工作流程需要怎么重构？

如果你是AI治理决策者：当“不公开发布”成为唯一的安全选择，开源AI的价值观该如何安放？

本文来源：[鸿铭晟干货库](#)

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时权益申领

* 体验资格每人限申领一次

扫码
免费领取

VIP会员·7天畅读卡 | 大师课·入门串讲



限免

👍 91 ⭐ 收藏

分享到:

写评论

请发表您的评论

表情 图片

发表评论